

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control	Explanation
	X	Least Privilege	<i>In the risk assessment report it is claimed that access controls pertaining to least privilege and separation of duties have not been implemented. We do not want all employees to have access to customer data; Employees should have access to the data and resources needed to do their job. Not more or less.</i>
	X	Disaster recovery plans	<i>There are no disaster recovery plans in place. DRP ensure that data is secure and operations can quickly resume after disruptive events (ransomware attacks, power outages, hardware failures etc.)</i>
	X	Password policies	<i>Password policy exists but its requirements are nominal. This can lead to weak passwords that can easily get cracked.</i>

	X Separation of duties	<i>Needs to be implemented to reduce the possibility of fraud/access to critical data. No single individual should have unchecked control over an entire critical process.</i>
X	Firewall	<i>The risk assessment report states that the IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.</i>
	X Intrusion detection system (IDS)	<i>No IDS in place. IDS is a security device that monitors traffic and can alert immediately when suspicious activity is detected.</i>
	X Backups	<i>No Backups of critical data. Backups are really important because a hardware failure, an accidental deletion, a malware attack can lead to unrecoverable loss of data.</i>
X	Antivirus software	<i>Antivirus software is installed and monitored regularly by the IT department.</i>
	X Manual monitoring, maintenance, and intervention for legacy systems	<i>Maintenance should not happen randomly or when something breaks. And if something happens there must be a documented set of instructions in order to respond to that.</i>

	X	Encryption	<i>Encryption is not currently used. It is a great way to provide confidentiality of sensitive information.</i>
	X	Password management system	<i>There is no password management system currently in place. This leads to weak passwords and to productivity bottleneck.</i>
X		Locks (offices, storefront, warehouse)	<i>The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks.</i>
X		Closed-circuit television (CCTV) surveillance	<i>CCTV is installed at the store.</i>
X		Fire detection/prevention (fire alarm, sprinkler system, etc.)	<i>There is a functioning fire detection and prevention system in place.</i>

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Explanation
	X	Only authorized users have access to customers' credit card information.	<i>Currently, all Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.</i>

X	Credit card information is accepted, processed, transmitted, and stored internally, in a secure environment.	<i>Credit card information is not encrypted. All employees have access to customers' credit card information.</i>
X	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	<i>No encryption procedures in place. Data is accessible to all employees.</i>
X	Adopt secure password management policies.	<i>Password policies are nominal and no password management system is currently in place.</i>

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Explanation
	X	E.U. customers' data is kept private/secured.	<i>Data is accessible to all employees, no encryption in place.</i>
X		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	<i>The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach.</i>
	X	Ensure data is properly classified and inventoried.	<i>Assets have been listed, but there is no classification of the assets. This leads to waste of money and high risk of breaches because assets are not protected well.</i>

X	Enforce privacy policies, procedures, and processes to properly document and maintain data.	<i>Privacy policies, procedures, and processes have been developed and are enforced among IT department members/other employees, to properly document and maintain data.</i>
---	---	--

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Explanation
	X	User access policies are established.	<i>All employees have access to private customer information. The principles of Least Privilege and Separation of Duties should be implemented as soon as possible.</i>
	X	Sensitive data (PII/SPII) is confidential/private.	<i>All employees have access to PII/SPII. No encryption in place.</i>
X		Data integrity ensures the data is consistent, complete, accurate, and has been validated.	<i>The IT department has ensured availability and integrated controls to ensure data integrity.</i>
	X	Data is available to individuals authorized to access it.	<i>No, that is not the case. Principle of Least Privilege needs to be implemented. This way only employees that need access to this data to do their job will have access.</i>

Recommendations:

*To significantly improve Botium Toys' security posture and score, immediate administrative changes must be made regarding identity access management. The IT department should enforce the principles of **Least Privilege** and **Separation of Duties** to ensure employees only interact with data vital to their specific jobs. Furthermore, to address severe compliance vulnerabilities under PCI DSS and GDPR, the organization must implement **Data Encryption** for cardholder data in transit and at rest, alongside an enterprise **Password Management System**. Finally, to ensure business continuity against hardware failures or cyber threats, the company must establish robust **Data Backups** and a formalized **Disaster Recovery Plan (DRP)**, while introducing an **Intrusion Detection System (IDS)** to monitor anomalous network traffic.*